Exploiting a Vulnerable Web Application

A Home Lab Penetration Testing Write-Up

Sample Write-Up | Isolated home lab (VirtualBox) | Beginner | Web Application Security

Overview

A full web application assessment against a deliberately vulnerable target, covering recon, enumeration, exploitation, privilege escalation and reporting. All testing was done in a fully isolated, self-hosted lab with no internet-facing exposure, in line with ethical practice.

Lab Environment

Attacker	Kali Linux VM, internal network only
Target	Custom vulnerable web app VM (host-only network)
Scope	Target VM only. No external systems in scope.

Methodology

1. Reconnaissance. Nmap found SSH (22) and HTTP (80) running an outdated PHP app.

```
nmap -sC -sV -p- 10.10.10.15
```

2. Enumeration. Gobuster uncovered an admin login and an unlinked upload endpoint.

```
gobuster dir -u http://10.10.10.15 -w common.txt -x php
```

3. Exploitation. The upload endpoint didn't validate file type or content, so a script disguised as an image was executed by the server, giving a low-privilege reverse shell.

4. Privilege escalation. Enumeration flagged a scheduled task whose script was writable by the low-privilege account. Replacing it gave a shell as the higher-privileged user on the next run.

Key Findings

- **Unrestricted file upload:** no type or content validation, allowing script execution.
- **Hidden endpoints found by brute force:** unlinked pages were still reachable.
- **Insecure scheduled task permissions:** low-privilege write access to a high-privilege script.

Remediation

- Validate uploads server-side (not just by extension) and store them outside the web root.
- Apply least-privilege permissions so lower-privileged accounts can't modify scheduled tasks.
- Don't treat unlinked pages as security. Enforce authentication on sensitive endpoints.

Tools Used

Nmap (port scanning) • Gobuster (directory enumeration) • Netcat (reverse shell listener) • Custom enum script (privesc checks)

Conclusion

Small misconfigurations, an unvalidated upload field and an overly permissive scheduled task, can chain into full system compromise, which is why defence-in-depth matters at every layer.

Carried out entirely within an isolated, self-hosted lab for educational purposes. No real-world systems were accessed. This is a placeholder sample write-up to test the PDF-based project format; replace with your own project details and findings.